

MEDISYNC SOLUTIONS

INCIDENT RESPONSE POLICY

CONFIDENTIAL | INTERNAL USE ONLY

Document ID:	POL-004
Version:	1.0
Owner:	CISO — Isha Gupta
Approved by:	CEO — Marcus Chen
Effective Date:	September 1, 2026
Review Date:	September 1, 2027
ISO 27001 Ref:	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28
HIPAA Ref:	§164.308(a)(6), §164.308(a)(7), §164.400–414 (Breach Notification)
NIST CSF Ref:	RS.MA-01–05, RS.AN-03, RS.CO-02, RS.MI-01–02, RC.RP-01

1. Purpose & Scope

This policy establishes MediSync Solutions' framework for detecting, containing, eradicating, and recovering from information security incidents — with particular emphasis on protecting PHI processed on behalf of 47 hospital systems, 312 physician practices, and 8 ACOs. It applies to all employees, contractors, and third parties; all systems including the Care Platform, FHIR API, AWS environment, and Cleveland HQ on-premises infrastructure; and all security events that may affect the confidentiality, integrity, or availability of MediSync information assets.

2. Incident Classification

All security events are classified using the following priority levels:

- P1 — Critical: Active PHI breach, ransomware, Care Platform fully down, confirmed system compromise. Respond within 1 hour. CISO and CTO notified immediately. Escalate to CEO within 2 hours.
- P2 — High: Suspected PHI breach, significant malware contained, major vulnerability under active exploitation, Care Platform degraded. Respond within 4 hours. CISO notified within 1 hour.
- P3 — Medium: Policy violation, phishing attempt contained, minor unauthorized access, vulnerability requiring prompt remediation. Respond within 24 hours. IT Manager notified same day.
- P4 — Low: Suspicious activity with no confirmed impact, minor policy breach, single failed login anomaly. Respond within 72 hours. Documented and monitored.

All employees report suspected incidents to security@medisync.com. Splunk Cloud alerts automatically notify the Security Engineer on duty for P1 and P2 events.

3. Incident Response Phases

Phase 1 — Detection & Identification

Incidents are detected via Splunk Cloud SIEM alerts, Qualys vulnerability findings, EDR endpoint alerts, WAF events, employee reports, vendor notifications, or customer reports. The Security Engineer performs initial triage, assigns a priority classification, opens a ticket, and notifies appropriate personnel per the escalation chain.

Phase 2 — Containment

Short-term containment: isolate affected systems, block malicious IPs at WAF, disable compromised Okta accounts, revoke exposed credentials. Forensic evidence is preserved before remediation — AWS CloudTrail logs and Splunk data are locked. Long-term containment: implement compensating controls to allow business continuity while full eradication is underway.

Phase 3 — Eradication

Remove the root cause: patch exploited vulnerabilities via Qualys, remove malware using EDR, close unauthorized access paths in AWS IAM and Okta. Conduct environment-wide scan to confirm no residual compromise. CISO reviews and approves eradication completeness before recovery begins.

Phase 4 — Recovery

Restore affected systems from clean AWS RDS snapshots or S3 backups. Validate system integrity before returning to production. Monitor all restored systems in Splunk Cloud for 30 days post-recovery. The Care Platform RTO is 4 hours; the DR environment in AWS us-west-2 is activated if the primary us-east-1 region is unavailable. CTO approves return to production for all P1 incidents.

Phase 5 — Post-Incident Review (Lessons Learned)

A post-incident review is conducted within 14 days of closure for all P1 and P2 incidents. The review documents the incident timeline, root cause, effectiveness of response, and recommended improvements. Findings are recorded in the lessons learned register by the GRC Analyst. Improvements are assigned to named owners with target completion dates and tracked to closure.

4. HIPAA Breach Notification

When an incident involves PHI, the CISO applies the HHS four-factor breach risk assessment to determine whether a reportable breach occurred: (1) nature and extent of PHI involved; (2) who accessed or could have accessed the PHI; (3) whether PHI was actually acquired or viewed; (4) extent to which risk has been mitigated. If a reportable breach is confirmed:

- HHS (OCR) notification: within 60 calendar days of discovery. Breaches affecting 500+ individuals in a state: simultaneous with individual notification.
- Individual notification: within 60 calendar days via first-class mail or pre-authorized email.
- Media notification: if the breach affects 500+ residents of Ohio, Florida, Texas, or California, prominent state media outlets are notified within 60 days.
- Business Associate notification: covered entity (hospital customer) notified without unreasonable delay and within 60 days if breach originates at MediSync.

Legal counsel is notified for all P1 incidents and all confirmed PHI breaches. The CISO maintains a breach log for 6 years documenting all breach determinations — confirmed and assessed-as-not-reportable.

5. Communication Chain

P1: Security Engineer → CISO (immediate) → CTO (within 30 min) → CEO (within 2 hours) → Legal counsel → affected hospital customers per BAA → HHS if breach confirmed. P2: Security Engineer → CISO (within 1 hour) → CTO if Care Platform affected. All incidents: documented in ticketing system with timestamps. External communications require CISO and CEO approval before release.

6. Enforcement, Exceptions & Review

Failure to report a known security incident is a policy violation subject to disciplinary action. Exceptions to response timeframes require CISO approval and documentation. This policy is reviewed annually, after any P1 or P2 incident, and following changes to HIPAA regulations or MediSync's technical environment. IR tabletop exercises are conducted at least annually; findings are incorporated into policy updates.